

SchoolApp360 — Fix Checklist (Priority Ordered)

Work top to bottom. Each item is independently fixable and checkable off.

CRITICAL — fix before any real school uses this

- ☐ 1. Remove hardcoded SuperAdmin password shown on the public login page; rotate the real credential — `components/SuperAdminLoginForm.jsx:17-18` , `prisma/seed.js:78,84`
 - ☐ 2. Add auth guard to `POST /api/fees/collect` — `app/api/fees/collect/route.js`
 - ☐ 3. Add auth guard to `POST /api/fees/structures` — `app/api/fees/structures/route.js`
 - ☐ 4. Add auth guard to `GET/POST/DELETE /api/fees/students/[id]/discount` — `app/api/fees/students/[id]/discount/route.js`
 - ☐ 5. Add auth guard to `PUT /api/school/profile` — `app/api/school/profile/route.js`
 - ☐ 6. Add auth guard to `/api/school/branding` , `/contact` , `/preferences` , `/attendance-settings`
 - ☐ 7. Add auth guard to `/api/sessions` and its `[id]` `activate/archive` actions
 - ☐ 8. Add auth guard to `POST /api/admins/[id]/reset-password`
 - ☐ 9. Add auth guard to `POST /api/admins/[id]/permissions`
 - ☐ 10. Add auth guard to `POST /api/admins/[id]/status`
 - ☐ 11. Add auth guard to `POST /api/schools/[id]/manage` — `app/api/schools/[id]/manage/route.js`
 - ☐ 12. Stop using `globalThis.__CURRENT_USER__` for any real auth decision — route every consumer through the real session instead — `lib/currentUser.js:12`
 - ☐ 13. Remove the `getActiveSchoolId()` default fallback from `lib/students.js` / `lib/teachers.js` exported functions — make `schoolId` required
 - ☐ 14. Fix the `Student` / `StudentFee` / `Payment` `cascade-delete` crash — add a soft-delete status (`TransferredOut` / `Graduated`) instead of hard delete — `prisma/schema.prisma` , `lib/students.js:342-350`
 - ☐ 15. Rotate `JWT_SECRET` in the production environment; confirm it's no longer the demo value from `.env`
 - ☐ 16. Fix the null-actor ownership bypass on `GET /api/fees/student/[studentId]/summary`
-

HIGH — fix before scaling past a handful of schools

- ☐ 17. Add rate limiting/lockout to all login endpoints (SuperAdmin, SchoolAdmin, Teacher, Parent)
- ☐ 18. Restrict `Access-Control-Allow-Origin: *` on `/api/**` or separate cookie-authenticated routes from it — `middleware.js:45`
- ☐ 19. Enforce `ADMIN_PERMISSIONS` in every `requireSchoolAdmin()` -gated route, or remove the permissions UI since it currently does nothing — `lib/adminConstants.js`
- ☐ 20. Paginate `getSchoolStudents` / `getAllStudents` at the query layer — `lib/students.js:101`
- ☐ 21. Paginate `getSchoolTeachers` / `getAllTeachers` at the query layer — `lib/teachers.js:152`
- ☐ 22. Paginate the 8+ unbounded `findMany` calls in fees — `lib/fees.js:78,417,431,519,688,826,1047,1076`
- ☐ 23. Add a date-range bound to attendance queries — `lib/attendance.js:178`

- ☐ **24.** Fix the fetch-all-then-slice-client-side pattern on the Students page — `app/dashboard/students/page.jsx:19-20` , `components/students/StudentsExplorer.jsx:88`
 - ☐ **25.** Fix the same pattern on the Teachers page — `app/dashboard/teachers/page.jsx:13-14` , `components/teachers/TeachersExplorer.jsx:45`
 - ☐ **26.** Migrate every `<img>` tag to `next/image` (Sidebar, Topbar, Students/Teachers tables, profile headers, school logo, branding preview)
 - ☐ **27.** Switch schema changes to `prisma migrate` with real migration history; add `prisma migrate deploy` to the build step
 - ☐ **28.** Build a refund workflow in `lib/fees.js` (currently `applyFeeDiscount` tells the caller to refund first, with no refund function anywhere)
 - ☐ **29.** Wire the configured late-fee fields into actual payable-amount calculations, or remove the late-fee config UI since it currently does nothing — `lib/fees.js:26-32,205-214,451,533`
-

MEDIUM

- ☐ **30.** Enforce upload size limits server-side on R2 presigned URLs (currently client-reported only) — `lib/storage.js:33-40`
 - ☐ **31.** Add zod validation (`lib/schemas.js` already has the schemas) to every mutating API route
 - ☐ **32.** Add `@@index([schoolId])` to the `Notice` model — `prisma/schema.prisma`
 - ☐ **33.** Add `@@index([schoolId])` to the `CalendarEvent` model — `prisma/schema.prisma`
 - ☐ **34.** Add `error.jsx` boundaries under `app/` (none exist anywhere right now)
 - ☐ **35.** Add `loading.jsx` to Students, Teachers, Fees, Exams, Attendance, Dashboard home
 - ☐ **36.** Add `aria-label` to icon-only buttons across `components/` (near-zero coverage today)
 - ☐ **37.** Add a keyboard focus trap to `components/Modal.jsx` (Escape works, Tab doesn't stay contained)
 - ☐ **38.** Build a real admissions/enrollment workflow (application → approval → enrollment) — currently "Add Student" is a direct record creation with no stages
 - ☐ **39.** Fix exam-result scoring order so an absence doesn't lock in a 0 before `retakeResultPolicy` merge logic runs — `lib/examResults.js:182-197`
 - ☐ **40.** Re-validate the attendance deadline/grace window when unlocking, not just when marking — `app/api/attendance/[id]/lock/route.js`
 - ☐ **41.** Scope `GET /api/exams/[id]` by the actor's `schoolId` — `app/api/exams/[id]/route.js:6-16`
-

LOW

- ☐ **42.** Confirm the plaintext demo credentials in `prisma/seed.js` / `lib/teacherSeedData.js` are never seeded against production; rotate if they are
- ☐ **43.** Split `lib/api.js` (1,514 lines) into per-domain files
- ☐ **44.** Split `lib/fees.js` (1,118 lines) into `structures/`/`payments` modules
- ☐ **45.** Move `lib/studentSeedData.js` out of `lib/` into `scripts/` or `prisma/seed/`
- ☐ **46.** Split `lib/schemas.js` (616 lines) into per-domain files, matching the rest of the codebase's convention
- ☐ **47.** Extract a shared stats helper to remove the duplication between `lib/students.js:100-124` and `lib/teachers.js:151-172`

- ☐ **48.** Improve mobile-responsive coverage on `TeachersExplorer.jsx` and `StudentFeeDetailPanel.jsx`
- ☐ **49.** Add retry/dead-letter handling for failed push notifications — `lib/pushTokens.js`
- ☐ **50.** Wire in an error-tracking/monitoring service (e.g. Sentry) — none exists beyond Vercel's own dashboard
- ☐ **51.** Document a backup/restore strategy for the Postgres database